

- Operational requirements.
- Security requirements.
- Technical procedures.
- Hardware, software, and other equipment.
- Team member contact information.
- Vendor contact information.
- Alternate and off-site facility requirements.
- Vital records.

When updating the business continuity program, management should document, track, and resolve any changes. Management should document, analyze, and review lessons learned from adverse events. Understanding these lessons allows management to prepare for future adverse events. Documented procedures for incorporating lessons learned should include:

- Identifying the failure(s).
- Determining the cause(s).
- Evaluating potential solutions.
- Implementing timely corrective actions as appropriate.
- Recording and reviewing corrective actions taken.

As part of the maintenance and improvement process, management should maintain version control of key business continuity documents and ensure that the latest versions are readily available to appropriate personnel. The level of detail in documentation should be commensurate with the nature of the entity's operations. This information should be accessible during an event and can be maintained by BCM program management and personnel. The BCM documentation should include evidence substantiating periodic updates of the BIA, risk assessment, and BCP(s).

Business continuity document management processes may include the following:

- Roles and responsibilities.
- Document control.
- Version control.
- Storage and disposal.

Management should follow the entity's information security standards for confidential or sensitive information contained within business continuity documentation. Additionally, management should maintain backup copies of relevant business continuity documentation in the event that the primary repository becomes inaccessible.

IX Board Reporting

Action Summary

The board should establish expectations for management's business continuity reporting, regularly monitor business continuity and resilience activities, and provide credible challenges to management.

Examiners should review reports and meeting minutes and conduct discussions with management on the following:

- BIA.
- Risk assessment.
- BCP.
- Resilience.
- Exercise and test results.
- Identified issues.
- Strategy updates.
- Audit results.
- Metrics, including key risk indicators and key performance indicators for BCM and resilience.

As illustrated in figure 1, management should report on the status of business continuity to the board, completing the BCM cycle. Reports should include a written presentation providing the BIA, risk assessment, BCP, exercise and test results, and identified issues. Additionally, reports should include regular strategy updates based on changes in personnel, roles and responsibilities, and business operations. The board should monitor business continuity and resilience activities regularly to verify that they are implemented as envisioned and reviewed periodically or as changes dictate. The board should be updated in a timely manner based on lessons learned. Board minutes should reflect business continuity discussion (including credible challenges) and approvals.

Appendix A: Examination Procedures

Examination Objective

These examination procedures (also known as the work program) are intended to assist examiners in determining the quality and effectiveness of the business continuity process on an enterprise-wide basis or across a particular line of business. Additionally, these procedures assist examiners in evaluating whether business continuity testing demonstrates the entity's ability to meet its business continuity objectives including management's ability to recover, resume, and maintain operations after disruptions, ranging from minor outages to full-scale disasters. Examiners are not limited by the examination procedures presented here and may choose to use only certain components of the work program based on the size, complexity, and nature of the entity's business. Depending on the examination objectives, a line of business can be selected to sample how the entity's continuity planning or testing processes work individually or for a particular business function or process.

Objective 1: Determine the appropriate scope and objectives for the examination.

1. Review past reports for outstanding issues or previous problems. Consider the following:
 - a. Regulatory reports of examination.
 - b. Internal and external audit reports.
 - c. Reports by independent risk management.
 - d. Business continuity tests.
 - e. Regulatory, audit, and business continuity reports on third-party service providers.
2. Review management's response to issues identified during or subsequent to the last examination. Consider the following:
 - a. Adequacy and timing of corrective action.
 - b. Resolution of root causes rather than symptoms.
 - c. Status of uncorrected issues.
 - d. Retesting to validate corrective action.
3. Interview management and review responses to pre-examination information requests to identify changes to technology infrastructure or new products and services that could affect business resilience. Consider the following:
 - a. Products or services delivered to either internal or external users.
 - b. Network topology or diagram, including changes to configuration or components and all internal and external connections.
 - c. Hardware and software inventories.
 - d. Loss, addition, or change in duties of key personnel.
 - e. Third-party service providers and software vendor listings.
 - f. Changes to internal business processes.
 - g. Changes based on industry changes or threat intelligence.

4. Review newly identified threats and vulnerabilities to the continuity of operations. Consider the following:
 - a. Technology and security vulnerabilities.
 - b. Internally identified threats.
 - c. Externally identified threats (e.g., cybersecurity alerts, pandemic alerts, or emergency warnings published by information-sharing organizations and government agencies).

Objective 2: Determine whether the board and senior management promote effective governance of business continuity through defined responsibilities, accountability, and adequate resources to support the program. (II.A, “[Board and Senior Management Responsibilities](#)”)

1. Determine whether business continuity policies and critical business procedures are:
 - a. Up-to-date and reflective of the current business environment.
 - b. Communicated effectively throughout the entity.
 - c. Available during adverse events.
 - d. Securely maintained.
2. Determine whether the board and senior management provide leadership when overseeing business continuity, including:
 - a. Evaluating continuity risk.
 - b. Setting short- and long-term continuity objectives.
 - c. Adopting appropriate policies and procedures.
 - d. Evaluating continuity performance.
 - e. Adjusting programs and operations in response to test results and actual events.
3. Determine whether management strengthens resilience through the following:
 - a. Assessing continuity risk.
 - b. Resilience planning.
 - c. Testing business continuity plans.
 - d. Incorporating lessons learned from testing and events.
 - e. Considering resilience in business functions and the design of existing operations and new products and services.
4. Determine whether board oversight includes the following:
 - a. Assigning business continuity responsibility and accountability.
 - b. Allocating resources to business continuity (e.g., personnel, time, budget, and training).
 - c. Aligning BCM with business strategy and risk appetite.
 - d. Understanding business continuity risks and adopting appropriate policies and plans to manage events.
 - e. Understanding business continuity operating results and performance.

- f. Providing a credible challenge to management responsible for the business continuity process (e.g., the board minutes provide evidence of active discussions).
 - g. Establishing a provision for management intervention if timeliness for corrective action is not met.
5. Determine whether management oversight of business continuity includes the following:
- a. Defining business continuity roles, responsibilities, and succession plans.
 - b. Allocating knowledgeable personnel and sufficient financial resources.
 - c. Validating that personnel understand their business continuity roles.
 - d. Establishing measurable goals against which business continuity performance is assessed.
 - e. Designing and implementing a business continuity exercise strategy.
 - f. Confirming that exercises, tests, and training are comprehensive and consistent with the exercise strategy.
 - g. Resolving weaknesses identified in exercises, tests, and training.
 - h. Meeting regularly to discuss policy changes, testing plans, and training.
 - i. Assessing and updating business continuity strategies and plans to reflect the current business conditions and operating environment for continuous improvement.
 - j. Aligning plans between business units across the enterprise.
 - k. Coordinating plans and responses with external entities.

Objective 3: Determine whether the board and senior management engage audit or other independent review functions to review and validate the design and operating effectiveness of the BCM program. (II.B, “[Audit](#)”)

1. Determine whether the board and senior management have engaged audit (or an independent review) to validate the design effectiveness of the business continuity program and whether controls are operating effectively.
2. Determine whether audit reports to the board and provides an assessment of management’s ability to manage and control risks related to continuity and resilience.
3. Determine whether audit leverages SOC reports and other external artifacts from third-party service providers, as appropriate.
4. Determine whether the board or management validates that the auditor is qualified to carry out the review and is independent of the business continuity or related functions.
5. Evaluate the audit coverage of business continuity, whether through a general controls audit, during audits of business lines, or as a stand-alone business continuity audit. Audit coverage should include the following:
 - a. The reasonableness and comprehensiveness of the BIA and business continuity risk assessment(s).
 - b. The reliability, adequacy, and effectiveness of continuity and resilience controls.

- c. The effectiveness of risk mitigation efforts.
- d. Whether test plans achieve their stated objectives based on reasonable assumptions.
- e. Audit monitoring of exercises and tests, reviewing test plans and results, and verifying that any issues are identified and appropriately escalated.
- f. Assessment of the business continuity program effectiveness.

Objective 4: *Determine whether management developed an appropriate and repeatable BIA process that identifies all business functions and prioritizes them in order of criticality, analyzes related interdependencies, and assesses a disruption’s impact. (III.A, “[Business Impact Analysis](#)”)*

1. Determine the process through which management inventories business functions. Management may use the following artifacts to identify the functions:
 - a. Organizational charts.
 - b. Work flows (also called process maps).
 - c. Interview notes.
 - d. Network diagrams/topologies.
 - e. Data flow diagrams.
2. Determine whether management inventoried the critical assets and infrastructure upon which business functions depend, including the identification of single points of failure. Critical assets and infrastructure may include the following:
 - a. People.
 - b. Hardware.
 - c. Software.
 - d. Cash reserves.
 - e. Supporting activities (e.g., technology support, payroll, contracting).
 - f. Supporting software (e.g., email, office productivity suites).
 - g. Network connectivity.
 - h. Communication lines.
 - i. Facilities.
 - j. Utilities.
 - k. Infrastructure and services provided by third-party service providers.
3. Determine whether the interdependency analysis includes the following:
 - a. Internal systems and business functions, including services, production processes, hardware, software, and application programming interfaces, data, and vital records.
 - b. Third-party service providers, key suppliers, and business partners.
 - c. Telecommunications single points of failure.
 - d. Power single points of failure.
4. Review the BIA to determine whether the prioritization of business functions is reasonable. Consider management’s ability to do the following:

- a. Determine the operational and financial impacts of a disruption.
 - b. Aggregate loss impacts and determine a rating scale to indicate impact severity.
 - c. Reconcile BIA and risk assessment results with prioritization and document whether the reconciliation is adequate.
5. Determine whether the BIA produces sufficient information to estimate the following:
- a. Recovery point objectives (RPO).
 - b. Recovery time objectives (RTO).
 - c. Maximum tolerable downtime (MTD).

Objective 5: Determine whether management conducts a risk assessment sufficient to evaluate the likelihood and impact of potential disruptions and events. (III.B, “[Risk Assessment](#)”)

1. Review risk assessment(s) to determine whether management has identified all reasonably foreseeable hazards and threats to the continuity and resilience of the entity. Examples of risks can include:
 - a. Natural:
 - Flood, earthquake, hurricane, tornado, and other weather events.
 - b. Technological:
 - Technological: Malware, cyberattack, and hardware and software failure.
 - Operational: Critical infrastructure disruption (e.g., transportation and water systems).
 - c. Adversarial or human-caused:
 - Personnel: Strike, pandemic, and malicious insider.
 - Social: Terrorism, vandalism, looting, riots, and protests.
 - d. Combination:
 - Facility: Fire, power outage, and loss of access.
 - Geographic-related: Proximity to railroad or highways used for transport of hazardous materials, proximity to airports, traffic difficulties, and other issues.
 - Third-party: Services concentrated in a limited number of third-party service providers.
2. Determine whether management identifies BCM risks and coordinates risk identification efforts throughout the entity to identify systemic threats.
 - a. Determine whether management identifies and inventories the following:
 - Internal and external assets.
 - Types of threats and hazards.
 - Existing controls.
 - b. Verify that the risk assessment includes the identification of cybersecurity risks and results of information security risk assessments.
 - c. Assess whether management obtains information about hazards and threats from external sources.
 - d. Determine whether management considers threat intelligence in risk identification efforts.

3. Ascertain whether management identifies interconnectivity points between the entity and its third-party service providers, as well as interconnectivity between other entities and their third-party service providers (i.e., supply chain).
4. Determine whether the risk assessment includes the impact and likelihood of potential disruptive events, including worst-case scenarios.
5. Determine whether management identifies and analyzes gaps between the entity's risk exposure and the risk appetite, and documents any controls implemented to mitigate the residual risk.

Objective 6: Determine whether the entity's risk management strategies are designed to achieve resilience. (IV.A, "[Resilience](#)")

1. Verify that management has evaluated strategies and resource needs and allocates appropriate resources to achieve resilience:
 - a. Appropriate personnel and skillsets to carry out the functions.
 - b. Time to identify and implement solutions.
 - c. Budget to accomplish resilience goals and objectives.
2. Determine whether management has implemented physical resilience measures that:
 - a. Establish redundant communications between branches and data centers.
 - b. Identify multiple power sources.
 - c. Geographically diversify key entity locations.
3. Determine whether management has implemented data and cyber resilience measures that:
 - a. Maintain confidentiality, integrity, and availability for backup, replication, and production environments.
 - b. Implement appropriate backups and sufficient documentation and retention periods for each iteration of data backup.
 - c. Periodically reassess backup and recovery strategies as technology and threats change.
 - d. Maintain an accessible, off-site repository of software, configuration settings, and related documentation.
 - e. Establish procedures to recover critical networks and systems, including:
 - Backup types (physical or virtual).
 - Backup levels (full, incremental, or differential).
 - Update and retention cycle frequencies.
 - Software and hardware compatibility reviews.
 - Data transmission controls.
 - Data repository maintenance.
 - f. Protect offline data backups from destructive malware that may corrupt production and online backup versions of data.

4. Determine whether management documented and implemented, as appropriate, the following resilience measures for personnel:
 - a. Staffing and skills needed to operate critical functions related to business continuity.
 - b. Lodging arrangements for displaced employees and their families.
 - c. Basic necessities and services for displaced employees, including water, food, clothing, childcare, and transportation.
 - d. On-site medical support and mobile command centers.
 - e. Secure telecommunication options if employees work from an alternate location.
 - f. Designated emergency personnel, including critical business process-level employees (i.e., those necessary to ensure all critical business operations function appropriately).
5. Determine whether management documented and implemented, as appropriate, the following resilience measures for third-party service providers:
 - a. Considered disruptive events that threaten the operational resilience and viability of the entity's third-party service provider.
 - b. Assessed the entity's immediate or short-term space, systems, and personnel capacity to assume or transfer failed operations.
 - c. Assessed critical third-party service providers' susceptibility to multiple event scenarios.
 - d. Reviewed third-party service provider's resilience capabilities, including available test and SOC reports.
 - e. Verified that SLAs with third-party service providers align with the entity's recovery objectives.
 - f. Established plans for the resilience of third-party service providers supporting critical operations.
6. Determine whether management documented and implemented, as appropriate, the following resilience measures for telecommunications:
 - a. Identifying and mitigating single points of failure across the entity's infrastructure.
 - b. Developing and maintaining a plan to address an outage in the telecommunications lines with its primary third-party service providers.
 - c. Establishing redundant telecommunications links with each of the entity's third-party service providers through a contractual arrangement that allows either party to switch its connection to an alternate communication path.
 - d. Reviewing the entity's third-party service providers' plans and determining whether critical services can be restored within time frames acceptable to the entity.
 - e. Developing guidelines, commensurate with the entity's size, complexity, and risk profile, to diversify connections to mitigate the risk of a telecommunications failure.
 - f. Assessing the communications technology that bridges the transmission distance between the telecommunications service provider and the entity for single points of failure.
 - g. Monitoring relationships with telecommunications providers to manage risks.
 - h. Evaluating communications and resilience needs to ensure branch communications.

- i. Inquiring about the physical paths used by telecommunications providers and verifying that system redundancies have been properly implemented.
7. Determine whether management considers the following as part of the entity's power resilience strategies:
 - a. Alternate energy sources (e.g., generators and multiple power grids).
 - b. Fuel requirements, both for fuel on-hand and contracts with suppliers for deliveries during events.
 - c. Continued maintenance of generators.
 - d. Testing of generators.
8. Verify that BCM activities align with the entity's change management process.

Objective 7: Determine whether the entity's BCM includes communication protocols. (IV.B, "[Communications](#)")

1. Determine whether management considers, plans for, and prepares multiple mechanisms to communicate with personnel and other stakeholders while maintaining appropriate controls to safeguard customer information. Other stakeholders could include:
 - a. Regulatory agencies (federal and state).
 - b. Emergency responders.
 - c. Law enforcement.
 - d. Financial sector trade associations.
 - e. Information-sharing entities (e.g., FS-ISAC).

Objective 8: Assess the appropriateness of the entity's enterprise-wide BCP. (V, "[Business Continuity Plan](#)")

1. Verify that management implemented a comprehensive BCP that is reflective of the entity's risk environment. The BCP should outline the following:
 - a. Roles, responsibilities, and required skills for entity personnel and third-party service providers.
 - b. Solutions to various types of foreseeable disruptions, including those emanating from cyber threats.
 - c. Escalation thresholds.
 - d. Immediate steps to protect personnel and customers and minimize damage.
 - e. Prioritization and procedures to recover functions, services, and processes.
 - f. Critical information protection (e.g., physical, electronic, hybrid, and use of off-site storage).
 - g. Logistical arrangements (e.g., housing, transportation, or food) for personnel at the recovery locations.
 - h. Network equipment, connectivity, and communication needs, including entity-owned and personal mobile devices.